PENSE-BÊTE · MÉTHODES ET GOUVERNANCE

Exercice de crise cyber agroalimentaire

03-800 ANSSI - Kit d'exercice de crise cyber du secteur agroalimentaire — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Le kit propose trois niveaux de maturité allant de l'exercice sur table pour les débutants à la simulation pour les organisations matures.
2. L'attaque repose sur un accès VPN via des identifiants non révoqués d'un employé parti et combine un initié malveillant avec un collectif hacktiviste.
3. L'évaluation s'appuie sur une grille d'observation notée de 0 à 3 qui vérifie le respect du cycle alerte, qualification, gestion et clôture.

Présentation du kit ANSSI

Notion	À retenir
Les objectifs	Simuler une crise cyber (publié **juin 2026**) pour sensibiliser, favoriser la **synergie**, tester les **processus de gestion de crise/continuité** et améliorer la **réponse aux incidents**.
Niveaux de maturité	Niveau **1** : **exercice sur table**, débutants sans procédures ; niveau **2** : **simulation**, organisation intermédiaire avec procédures ; niveau **3** : **simulation**, organisation mature (robustesse, décision sous pression). Outil d'auto-évaluation ANSSI.
Les deux formats	Exercice sur table (**~3h**) ou Simulation (**0,5 à 1 journée**). Incluent **20 min** d'accueil/briefing, **10 min** de pause et **40 min** de débriefing à chaud.

Organisation de l'exercice

Notion	À retenir
Les six étapes	1. **enjeu et objectifs** ; 2. **type d'exercice** ; 3. **parties prenantes** ; 4. **documents supports** ; 5. **adaptation scénario** ; 6. **organisation pratique**.
Les rôles	**Planificateur** (objectifs, scénario, logistique, RETEX à froid), **Animateur** (déroulement, stimuli, RETEX à chaud), **Observateur** (notes, grille d'observation), **Joueur** (réagit aux stimuli).
Les règles de jeu	Aucune **action technique** réelle. Communication : mention `EXERCICE` **3 fois à l'oral** ET `[EXERCICE]` en objet courriel. Simulation : messagerie/télécoms **non touchées**, via `annuaire d'exercice` ou `cellule d'animation`.
Les familles de rôles	**Décision/Gouvernance** (pilotage) ; **Métiers/RH/Com** (activité, équipes, réputation) ; **Juridique/DPO/Finance** (légal, impacts) ; **IT/DSI/RSSI** (investigation, remédiation, autorités).

Scénario de l'attaque

Notion	À retenir
L'attaquant	Technicien informatique mécontent associé à un **collectif hacktiviste** (cause géopolitique). Objectif : **perturber la production** et décrédibiliser la sécurité.
Mode d'attaque	Intrusion via **accès VPN légitime** (identifiants non révoqués). Sabotage **IT/OT** (site web, automates, CRM) et **exfiltration de données**.
Les trois scénarios	**S1** : bloque CRM, exfiltre données, corrompt sauvegardes, modifie convoyeur (**SCADA**). **S2** : compromet site/ERP, altère ordres (**MES**). **S3** : multisite, supprime sauvegardes, attaque **SCADA** (DoS).

Déroulé du scénario 1

Notion	À retenir
Première journée	**H0-H1** : lenteurs, CRM inaccessible ; **H2** : revendication sur **X** (données clients, tarifs, commandes) ; **H3-H6** : anomalies du **convoyeur**, capteurs qualité désactivés ; **H8-H18** : suspicion d'action malveillante, mise en sûreté, prévenir **préfet**, **DGAL**, **ANSSI** ; arrivée du prestataire.
Deuxième journée	**J2 H0** : dernières sauvegardes > **1 an** ou incomplètes ; **J2 H1** : connexion d'un **employé licencié** (révoquer IT/OT, restaurer, vérifier comptes à privilèges) ; **J2 H4** : fausse information virale ; mode dégradé, **préfet, DGAL, DGCCRF, ANSSI** informés.

Évaluation de l'exercice

Notion	À retenir
La grille d'observation	Notée de **0 à 3** par les observateurs : **méthodologie**, **organisation**, **décision**, **réponse métier**, **support**, **communication** ; cycle **alerte, qualification, gestion, clôture**, points de situation, fiabilité des informations.
Les enseignements	Communiquer en interne et à l'extérieur, outiller la cellule, se préparer techniquement, décider dans l'incertitude ; après : date du **RETEX à froid**, actions de renforcement, plan de travail collectif.

Pièges et confusions

- ⚠ Confondre le niveau 1 (exercice sur table) avec les niveaux 2 et 3 (simulations)
- ⚠ Oublier que toute communication doit porter la mention EXERCICE
- ⚠ Croire que les observateurs doivent aider les joueurs pendant l'exercice
- ⚠ Ignorer que le vecteur d'entrée est un accès VPN légitime et non une faille technique inconnue
- ⚠ Confondre l'absence de sauvegardes récentes avec une simple panne technique

Sigles et définitions

TTX	exercice sur table fondé sur des discussions autour de situations projetées
Stimulus	message ou événement envoyé aux joueurs par l'animation
Chronogramme	outil central définissant la séquence des stimuli
Main courante	document consignant les actions et informations pendant la crise
OT	technologie opérationnelle désignant les systèmes industriels
SCADA	système de supervision contrôlant en temps réel les installations industrielles
RETEX	retour d'expérience à chaud ou à froid

Auto-test

1. Quelle est la durée d'un débriefing à chaud ?
2. Quelle mention doit figurer dans l'objet d'un courriel d'exercice ?
3. Qui est responsable du RETEX à froid ?
4. Quel est l'objectif du SCADA dans le scénario 1 ?
5. Quelles autorités du secteur agroalimentaire faut-il prévenir ?

Réponses : **1.** 40 min · **2.** [EXERCICE] · **3.** Le Planificateur · **4.** Contrôler le convoyeur · **5.** Le préfet, la DGAL, la DGCCRF et l'ANSSI

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.